

## MAT/MOUD Clinical Compliance Suite

A HIPAA and 42 CFR Part 2 Compliance Platform for Opioid Treatment Clinics — Built, Audited, and Hardened

*I spent five years as a Certified Recovery Specialist inside one of Philadelphia's largest health systems. I built this platform for the compliance problem I watched clinics struggle with every week, then audited my own code the way an external reviewer would — and found two critical defects in my own security controls.*

### THE PROBLEM, IN PLAIN TERMS

Clinics that treat opioid use disorder have to prove, continuously, that every clinician on staff holds a current license and credential. If a credential lapses, the clinic can lose the ability to bill, fail a state inspection, or in the worst case lose its license to operate. Most small clinics track this in a spreadsheet and a calendar reminder.

The complication is the data itself. These are substance use disorder treatment records, which are governed not only by HIPAA but by 42 CFR Part 2 — a stricter federal rule where the mere fact that someone is associated with an addiction treatment program is itself the protected information. General compliance tools are not built with that distinction in mind. This platform is.

### WHAT THE PRODUCT DOES

- Tracks provider credentials, licenses, and expiration dates for every clinician at a clinic.
- Sends automated alerts ahead of expiration, so a lapse is prevented rather than discovered during an audit.
- Stores supporting documents — licenses, certifications — encrypted, and releases them only to authorized staff through time-limited links.
- Records every access to protected information in a tamper-resistant log, which is what a clinic hands an auditor when asked to prove who saw what.
- Separates each clinic's data at the database level, so one clinic's records are structurally unreachable from another's.

### WHY I CAN BUILD THIS SPECIFICALLY

Five years of clinical case management at Philadelphia's second-largest healthcare organization, as a Certified Recovery Specialist and Patient Navigator, plus concurrent mobile CRS work across southeastern Pennsylvania. I have sat on the clinical side of this workflow and know where it actually breaks — which is rarely where a software vendor assumes it does. I also hold working relationships with providers at Thomas Jefferson University Hospital, Penn Medicine, and community clinics including Prevention Point, which is the population this product serves.

### HOW IT IS SECURED — EXPLAINED WITHOUT JARGON

**Multi-factor authentication.** A password alone is not enough to sign in. The system verifies that a genuine second factor — an authenticator app or a hardware key — was actually used, and rejects text-message codes, which are the weakest common option.

**Separation between clinics.** Each clinic's data is walled off by the database itself rather than by application code. This matters because application code can contain a mistake; this design means that even if a programmer forgets a filter in some future feature, one clinic still cannot see another's records.

**Need-to-know access.** Staff are grouped into three levels of access. The lowest level sees records with sensitive fields — Social Security numbers, dates of birth — automatically hidden. This implements HIPAA's "Minimum Necessary" principle: people see the least information required to do their job.

**A log nobody can edit.** Every access to protected information is written to a log that the application itself has no permission to modify or delete. Even if the application were fully compromised, the record of what happened cannot be rewritten.

**Encrypted documents, temporary links.** Uploaded documents are encrypted in storage. When an authorized user views one, the system issues a link that expires in five minutes, and logs the access before the link is created — so a document is never released without a record of it.

**Files are checked, not taken on trust.** When someone uploads a document, the system reads the file's actual contents to confirm it really is the type it claims to be, and rejects it if the two disagree. Stored files are also renamed to a random identifier, because filenames in a clinical setting often contain a patient's name — and under 42 CFR Part 2, the fact that a person is connected to addiction treatment is itself protected information.

### THE SECURITY AUDIT

Building security controls and verifying they work are different activities. I reviewed my own codebase file by file, the way I would review a system I had never seen, tracing every security claim the application makes back to the code that implements it and checking whether the implementation was actually correct — not merely present.

The most serious finding was in multi-factor authentication. The check was structurally correct, ran on every protected route, and the code comments stated plainly that MFA was enforced. But the list of accepted login methods included the identity provider's code for an ordinary password-only login. Every session passed. The control was doing nothing.

*The lesson generalizes beyond this project: a security control can be structurally correct and semantically wrong. Documentation and error messages are evidence of intent, not evidence of behavior. Reviewing the shape of a check is not reviewing the check.*

Eighteen findings were identified in total. Each was assigned a severity based on its impact on the confidentiality, integrity, and auditability of patient information — not on how difficult it was to fix — and mapped to the specific HIPAA Security Rule or 42 CFR Part 2 requirement it implicates, so that a compliance reviewer could act on the list rather than only an engineer.

| Severity | Found / Closed | What this level means                                                                    |
|----------|----------------|------------------------------------------------------------------------------------------|
| CRITICAL | 2 / 2          | Defeats a stated security control protecting patient data. Both closed.                  |
| HIGH     | 3 / 3          | Direct exposure or integrity risk, or a security feature that does not work. All closed. |
| MEDIUM   | 6 / 1          | Weakens defense in depth, or leaves a compliance obligation unevidenced.                 |
| LOW      | 7 / 1          | Hygiene, maintainability, and information-disclosure issues.                             |

*Every critical and high-severity finding is closed and regression-tested; nothing open exceeds medium. Closed findings are retained in the log with their remediation recorded, so the document functions as an audit trail rather than a to-do list.*

## HOW THE FIXES WERE APPROACHED

**Defense in depth over single fixes.** A development-only endpoint that was reachable in production was not simply gated. It is now excluded from the production build entirely, and independently permission-gated and logged everywhere else, so no single mistake re-exposes it.

**Fail closed.** Where a control depends on outside information, a missing or malformed value is treated as a failure rather than as an absent condition. The document-release path will refuse to issue a link if it cannot first write the audit record.

**Document the exclusion, not just the inclusion.** The corrected authentication list names each value that was deliberately left out and why, so the original mistake cannot be reintroduced by someone reasonably assuming an oversight.

**Prefer no dependency to a small one.** Validating that an uploaded file is genuinely the type it claims to be could have been a third-party package. For three permitted formats it is fifteen lines of explicit, auditable byte comparison instead — because every dependency added to a system holding patient data is surface someone else controls.

**Prove the test catches the bug.** Thirty-five automated tests now guard the corrected controls. Before accepting each suite, I restored the original defective code and confirmed the tests failed, then restored the fixes and confirmed they passed. A test that has never been shown to fail is not yet evidence of anything.

**Track honestly.** Eleven findings remain open and are documented as open, severity-ranked and sequenced. A findings log containing only closed items is not a security program.

## REGULATORY SCOPE — AND WHAT I CHOSE NOT TO BUILD

The platform targets HIPAA and 42 CFR Part 2, with 42 CFR Part 8 (the federal rule governing how opioid treatment programs operate) and NIST SP 800-66 Rev. 2 as the next additions. I also assessed and declined several frameworks that would have padded the feature list: HITECH is already covered by the HIPAA work rather than being a separate system, HITRUST certification is a paid third-party assessment no software can grant, and GDPR has no plausible trigger for clinics serving a Philadelphia patient population.

Deciding what not to build is part of the compliance analysis. Claiming coverage of a framework that does not apply signals a misread of the buyer's actual risk profile rather than thoroughness.

## SKILLS DEMONSTRATED

Secure application architecture · identity and access management (OIDC/JWT, MFA enforcement, role-based access control) · multi-tenant data isolation · PHI data-flow analysis · audit logging and evidence design · threat-informed manual code review · risk-based severity ranking · HIPAA Security Rule and 42 CFR Part 2 control mapping · remediation planning and sequencing · security regression testing · findings documentation for engineering and compliance audiences · translating technical risk for non-technical stakeholders.

## STATUS AND NEXT STEPS

Pilot-ready beta. Every critical and high-severity finding is closed and regression-tested; nothing open exceeds medium severity. Next in the remediation queue: removing a patient-name field that escapes the outbound-email PHI filter, extending database-level isolation to the audit table, and broadening test coverage to tenant isolation and access tiers. Beyond that: a continuous integration pipeline, and a Business Associate Agreement template — a legal prerequisite before any clinic can use the system with real patient data.